Daryadarcy App
Полный технический отчёт
аудит + FAQ + Роскомнадзор (14 пунктов)

Дата: 15.09.2026
Владелец: ИП Левина Дарья Сергеевна
Production: https://daryadarcy.com
Версия приложения: 1.0.0
Контакт для пользователей и Prodamus: daryadarcyapp@yandex.ru
Документ не содержит секретов, паролей и персональных данных пользователей.

1. Резюме

Daryadarcy - PWA/мобильное приложение бренда Darya Darcy: лента, видео, клуб по подписке, библиотека, магазин, интерактив (квиз). Backend на Node.js + tRPC, БД MySQL 8 (Timeweb), медиа - Timeweb S3, хостинг - VPS Timeweb (Россия).

Production online (smoke 02.09.2026: home, feed, api, trpc - 200). Автотесты: 30/30 (Vitest verify). Миграции 0015-0018 применены на production MySQL. Сентябрь 2026: boot-видео загрузки, карусель на главной, pen pals v2 (mutual confirm), блокировка в админке, комментарии с фото, cron retention, SMTP, Woolen, эффект "Тайинственный сад".

2. Окружения и роли

Окружение	URL / назначение
Production	daryadarcy.com - PWA + API
Локально	localhost:8081 (web), localhost:3000 (API)
Staging	Не развёрнут

Роли пользователей

- Гость - лента, видео, магазин, часть библиотеки
- Пользователь (users.role=user) - профиль, лайки, вход SMS/email
- Подписчик клуба - club_subscriptions активна - контент клуба, pen pals
- Администратор (role=admin) - CRUD контента, модерация

3. Технологический стек

- Клиент: React Native 0.81, Expo 54, Expo Router, TypeScript
- Web: Expo export (PWA), React Native Web
- API: Node.js, Express, tRPC 11, Zod, superjson
- БД: MySQL 8 utf8mb4, Drizzle ORM
- Файлы: Timeweb S3 (s3.twcstorage.ru)
- Auth: JWT cookie/Bearer, SMS.ru OTP, email+password (scrypt)
- Платежи: Prodamus (клуб, цифровые товары)
- Деплой: nginx + PM2 на VPS Timeweb

4. Персональные данные - поля профиля

Поле	Статус
Имя / ник (name)	Да - одно поле, отдельного псевдонима нет
Телефон	Да - вход по SMS, уникальный
Email	Да - вход, оплата, связь
Пол (gender)	Да - female / male
Аватар	Да - URL на S3
Дата рождения	Нет
Город в профиле	Нет - только в Pen pals (план: ФИО)
Пароль	Хеш scrypt - только email-вход

Дополнительные данные

- Pen pals: интересы (2-3), почтовый адрес, поле city (план: ФИО)
- Квиз: результат локально (AsyncStorage), не на сервере
- Лайки, сохранения, комментарии - привязка к userId
- Push-токен (Expo) - только native; marketing push - отдельное согласие

5. Авторизация

Способ	Сервис
SMS OTP	SMS.ru (sms.ru/sms/send), код SHA-256, TTL 5 мин
Email + пароль	Встроенная (/api/auth/register, /login)

Сторонних OAuth (Auth0, Firebase Auth, Яндекс ID) нет.

6. Инфраструктура и размещение данных

Важно: компоненты в разных зонах Timeweb. Cloud MSK 50 - это тариф VPS, не зона ЦОД. Production API - Москва MSK-1 (ru-3). MySQL и S3 - Санкт-Петербург SPB-3 (ru-1).

Компонент	Провайдер / зона / страна
Backend API (VPS daryadarcy-main)	Timeweb Cloud MSK 50, зона MSK-1, Москва, РФ
IP VPS	200.165.234.36 (ID 8271015)
База данных (Charming Aquila)	Timeweb MySQL 8.4, зона SPB-3, СПб, РФ
IP MySQL	77.95.206.157 (ID 4202401)
Изображения (S3 daryadarcy-s3)	Timeweb S3, ru-1 / SPB-3, endpoint s3.twcstorage.ru
Резервные копии MySQL	Timeweb: ежедневно 00:15 МСК, 1 копия (панель 31.08.2026)
Резервные копии VPS	Timeweb: включены; ЦОД хранения - уточнить в поддержке

Адреса ЦОД (Timeweb Cloud, docs timeweb.cloud)

- SPB-3 (MySQL, S3): Dataline, г. Санкт-Петербург, ул. Жукова, д. 43
- MSK-1 (VPS API): по документации Timeweb - IXcellerate, г. Москва, ул. Подольских Курсантов, 15Б, ст1 (точное здание для VPS 8271015 - запрос в поддержку Timeweb)

Timeweb: ООО ТАЙМВЭБ.КЛАУД, ИНН 7810945525. На VPS нет локальной копии БД пользователей - только обработка запросов и журналы.

7. Аналитика и сторонние SDK

Сервис	Используется
Яндекс Метрика	Нет
Google Analytics	Нет
Sentry	Нет
Firebase	Нет
Expo	Да - фреймворк, не аналитика
Expo Push	iOS/Android; web - нет; трансграничная передача (США)
Google Fonts CDN	Нет - шрифты встроены локально (assets/fonts/)
Локальные шрифты	Playfair, EB Garamond, Gogol, Woolen (бренд)

8. Сроки хранения и удаление

- Удаление аккаунта: запрос в профиле; cron processScheduledAccountDeletions - через 30 дней после окончания клуба
- Комментарии: автор отображается как "Удалённый аккаунт"; purge комментариев старше 90 дней (cron)
- Pen pals: purge неподтверждённых матчей, неактивных анкет 30+ дней, данных 90+ дней без клуба
- Данные банковских карт не хранятся - Prodamus
- Marketing push: push_consent_events + consentText (миграция 0018)
- user_consent_events: consentText (миграция 0017) - SMS, pen pals, push

9. Безопасность и доступ специалистов

- Журнал admin_audit_log: block/unblock пользователей (реализован)
- 2FA admin/moderator: TOTP при входе, если задан ADMIN_TOTP_SECRET в .env
- Роли: user / moderator / admin; blockedAt блокирует API
- MySQL backup из приложения: mysqldump -> S3, раз в 24 ч (server/_core/backup.ts)
- Timeweb: физические бэкапы MySQL + VPS (панель)
- SMTP: daryadarcyapp@yandex.ru (Yandex), SMTP_PASS на VPS

10. Почтовое отделение (Pen Pals)

Раздел для подписчиков клуба - подбор друга по переписке.

Реализовано (02.09.2026)

- 18+ checkbox, отдельное согласие, журнал user_consent_events
- Поле ФИО (fullName), не "Город"
- Подбор по интересам без раскрытия адреса до mutual confirm (7 дней)
- Взаимное подтверждение обоих участников; отзыв анкеты
- Cron: purge stale pen pal data

11. Цифровые товары (магазин)

- Товары: digital-1 (пособие по фото), digital-2 (мастер-класс)
- Оплата: Prodamus; email daryadarcyapp@yandex.ru на экранах магазина и в письме
- Автоотправка: server/shop-delivery.ts, очередь shop_delivery_emails, retry каждые 5 мин
- Сервисный push после успешной доставки (native)
- SLA в письме: "если не пришло за 15 минут - напишите на email"

12. Юридические документы

- Хаб /legal: оферта, политика ПД, согласие на ПД, пользовательское соглашение
- Оплата/отмена/возврат, cookie, реквизиты (shared/legal-documents.ts)
- Email везде: daryadarcyapp@yandex.ru
- Частично: реквизиты - ИП + email; полные банковские реквизиты - от Дарьи

13. Оптимизация производительности (август 2026)

- S3: 145 файлов оптимизировано, ~192 МБ экономии

- Бумажная текстура: 5.7 МБ -> 230 КБ
- Локальный бандл: PNG->WebP, JPG пересжатие (~120->~35 МБ assets)
- Скрипты: npm run optimize:s3, npm run optimize:assets

14. API (кратко)

tRPC: https://daryadarcy.com/api/trpc/ - auth, profile, feed, videos, club, admin, articles, shop, penPals, notifications.

Health: GET /api/health. REST: /api/auth/*, /api/prodamus/*, /api/pay/:id

15. База данных (таблицы без PII)

users, posts, post_media, tags, likes, saved_posts, videos, articles, club_subscriptions, club_payments, shop_purchases, post_comments, pen_pal_profiles, pen_pal_shown, push_tokens, push_consent_events, sms_codes.

Схема: drizzle/schema.ts, миграции drizzle/*.sql

16. Интеграции

- Timeweb MySQL, S3, VPS
- SMS.ru - OTP
- Prodamus - платежи
- YouTube - превью видео
- Expo Push - native уведомления

17. Автотесты

- __tests__/regression.test.ts - 18 тестов UI
- __tests__/quiz-data.test.ts - 12 тестов
- npm run verify - 30 тестов перед деплоем

18. Известные ограничения

- Нет staging-домена
- Нет E2E (Playwright/Detox)
- Email-регистрация без checkbox согласия на ПД
- anonymizeUserComments - stub (имя "Удалённый аккаунт" через users, текст комментария не меняется)
- 4 club-поста без видеофайла - нужен re-import
- ADMIN_TOTP_SECRET не задан - 2FA выключена до настройки
- Promo-карусель - временные обложки, ждут финальные от Дарьи
- 10 устаревших тестов screens.test.ts

19. Правила аудита на production

Разрешено

- Просмотр публичных разделов, UI/UX, responsive
- Тестовые аккаунты (не owner admin)
- npm run smoke

Запрещено

- Редактирование реальных постов без согласования
- Нагрузочное тестирование, реальные платежи
- Доступ к .env, SSH, БД, S3-ключам
- Экспорт персональных данных

20. Комплект поставки

- Архив исходников: daryadarcy_app_backup_YYYY-MM-DD.zip (~230 МБ)
- docs/ - AUDIT-PACKAGE, API, DATABASE-SCHEMA, INTEGRATIONS, KNOWN-ISSUES
- README.md, .env.example
- Не входит: .env, пароли, PII, полные server logs
- Тестовые аккаунты и NDA - отдельно

21. Push-уведомления (сервисные и рекламные)

Тип	Примеры / согласие
Сервисные	Оплата, подписка - без marketing opt-in
Рекламные	Новые посты, акции - только после явного согласия

В профиле (native): переключатель "Получать новости, новые публикации, акции". По умолчанию выключен. Backend: notifications.marketingConsent, setMarketingConsent, sendMarketingPostNotification фильтрует по согласию.

Трансграничная передача: Backend (РФ) -> Expo Push API (США) -> APNS/FCM. В push не передаются ФИО, адреса, платёжные данные - только заголовок и превью.

- Журнал: push_consent_events (userId, type, status, version, platform, date)
- Admin: purgeUserPushData при удалении аккаунта
- Документация: docs/PUSH-NOTIFICATIONS.md

22. Список задач по приложению (22 пункта)

Источник: "Задачи по приложению daryadarcy". Статус на 02.09.2026. DONE = реализовано; PARTIAL = частично; WAIT = нужны материалы/решение.

1	Загрузка: boot-видео, спиннер, Retry, WebP-сжатие	DONE 02.09
2	Email daryadarcyapp@yandex.ru везде для связи	DONE 02.09
3	Prodamus: зарубежные карты, 6 мес = 4740 руб, 180 дней клуба	DONE
4	Блокировка нарушителей в клубе (API + админка)	DONE 02.09
5	Юр. раздел: оферта, ПД, cookie, реквизиты	PARTIAL реквизиты
6	Push: сервисные / рекламные с opt-in	DONE
7	Pen pals: 18+, mutual confirm, FIO, purge	DONE 02.09
8	Профиль: подписка, отмена автопродления, возврат	DONE
9	Удаление аккаунта 30 дней, обезличить комментарии	PARTIAL cron
10	Комментарии среды: 48 ч, 2 фото, ссылки, replies	DONE 02.09
11	Модерация: delete, report, moderator, block	DONE
12	Безопасность: роли, 2FA, audit log, бэкапы	PARTIAL 2FA secret
13	Согласия: checkbox, версия, полный текст	PARTIAL email-reg
14	Автоотправка пособия/МК на email за 15 мин	PARTIAL SMTP
15	Клуб: оригинальная ориентация постов	DONE
16	Качество обложек видео в клубе	WAIT исходники

17	Rich text / ссылки	
18	Шрифт DARYADARCY -> Woolen	DONE
19	Главная: карусель promo	PARTIAL обложки
20	Видео: шиповники как на Интерактив	DONE
21	Видео: жирные названия	DONE
22	Эффект "Таинственный сад" + кнопка слева	DONE 02.09

Итого: ~14 выполнено, ~8 частично, 0 не начато.

23. Сведения для Роскомнадзора (кратко)

Оператор

ИП Левина Дарья Сергеевна. Сайт: https://daryadarcy.com

Инфраструктура Timeweb (данные из панели, 31.08.2026)

Сервис	Параметры	
MySQL Charming Aquila	ID 4202401, IP 77.95.206.157, MySQL 8.4	
Зона MySQL / S3	ru-1 = SPB-3, Санкт-Петербург	
Адрес ЦОД SPB-3	Dataline, ул. Жукова, д. 43, СПб	
S3 daryadarcy-s3	ID 513637, регион ru-1, endpoint s3.twcstorage.ru	
VPS daryadarcy-main	ID 8271015, IP 200.165.234.36, тариф Cloud MSK 50, зона MSK-1 (Москва)	

Даты начала (история Timeweb)

- S3 daryadarcy-s3: 5 июня 2026
- VPS daryadarcy-main (Ubuntu 24.04): 5 июня 2026
- MySQL Charming Aquila: 24 августа 2026
- Для заявления: начало обработки ПДн - не ранее 5 июня 2026 (инфраструктура); уточнить дату первых пользователей

DONE

Резервные копии

- MySQL: физические бэкапы включены, ежедневно с 00:15 МСК, хранится 1 копия (с 24.08.2026)
- MySQL: логические бэкапы выключены
- VPS: автобэкапы диска включены (последний: 31.08.2026 13:00); регион хранения - запрос Timeweb
- nginx logs: logrotate daily, rotate 14 (14 суток), compress - проверено на VPS 02.09.2026
- PM2 logs: pm2-logrotate установлен 15.09.2026 (max_size 10M, retain 14, compress, rotate 00:00 UTC)
- App MySQL backup: mysqldump -> gzip -> S3 backups/mysql/ ежедневно (последний 15.09.2026, ~479 KB)

Обработчики / инфраструктура

Контрагент	ИНН / роль	
ООО ТАЙМВЭБ.КЛАУД	7810945525 - VPS, MySQL, S3, РФ	
ООО СМС.РУ	7713461582 - OTP SMS, РФ	
ООО Продамус	1215156909 - платежи, РФ	
Expo / Apple APNS / Google FCM	push-токены, текст push, США	
Google (YouTube CDN)	превью видео, США	

Категории персональных данных

- Профиль: имя, email, телефон, пол, аватар, хеш пароля -> MySQL users
- SMS OTP: телефон, хеш кода -> sms_codes (TTL 5 мин)

- Подписка/оплата: orderId, email, сумма -> club_payments, club_subscriptions
- Магазин: orderId, email, productId -> shop_purchases
- Pen pals (опционально): интересы, город, почтовый адрес -> pen_pal_profiles
- Push: Expo token, platform; marketing consent -> push_tokens, push_consent_events
- Не храним: банковские карты (Prodamus), дату рождения, результат квиза (локально)

Трансграничная передача

Да: native push через Expo/APNS/FCM (США); превью YouTube (США). Цель: доставка уведомлений и отображение превью. Полная карта: docs/ROSKOMNADZOR-DATA-MAP.md

Чеклист перед подачей (для ИП)

- Реквизиты ИП и дата начала сбора ПДн
- Скрин Timeweb: зона MySQL/S3 и параметры бэкапов
- Обновить политику конфиденциальности (push, Timeweb, трансграничная передача)
- NDA с техническим специалистом (организационно)

24. Шрифт Woolen (бренд)

- Лицензия: куплена для сайтов; EULA в assets/fonts/Woolen-EULA.txt
- Файлы: Woolen-Regular.ttf (app), .woff / .woff2 (web)
- Применение: надпись DARYADARCY на главной, login, privacy, site
- Извлечение: npm run extract:woolen (из Woolen.zip)
- Google Fonts CDN не используется - все шрифты локально

25. Ответы на вопросы (31.08.2026)

Краткие ответы для ИП и заявления в Роскомнадзор.

Регистрация и аккаунт без клуба

Отдельная бесплатная регистрация ради регистрации не обязательна. Основной путь в клуб: оплата -> запись в базе -> вход.

- Без входа: лента, видео, магазин, часть библиотеки - как гость
- Клуб - только после оплаты; при оплате указывается email или аккаунт
- Вход: SMS (телефон) или email + пароль
- Полный личный кабинет DARCY (профиль, сохраненное, клуб) - только для участниц клуба

Итого: основные пользователи клуба - оплатившие и авторизовавшиеся; гостевой просмотр без регистрации тоже есть.

Подписка 6 мес. / 4740 руб. (зарубежные карты)

В коде: ровно 180 календарных дней с даты оплаты (или с конца текущего доступа, если подписка уже была). Это не 6 календарных месяцев (напр. 15 января -> 15 июля).

В тексте оплаты написано "6 месяцев", в системе считается 180 дней. Для документов рекомендуется: "180 дней (6 месяцев) с даты оплаты".

Push-уведомления

- Web/PWA: push сейчас нет - ни технически, ни в интерфейсе
- Переключатель согласия на рекламные push - только native iOS/Android

- На сайте переключатель не показываем до запуска push в PWA
- Backend-логика согласия готова про запас; для web не активируем

Для РКН: Expo Push в web/PWA сейчас не используется.

Роскомнадзор - дополнения

1. ЦОД MySQL, S3 и бэкапов

MySQL (Charming Aquila, 4202401) и S3 (daryadarcy-s3): зона ru-1 / SPB-3, Санкт-Петербург, Dataline, ул. Жукова, д. 43. VPS API (daryadarcy-main): Cloud MSK 50, Москва (ПД хранятся в MySQL SPB, не на диске VPS). Бэкапы MySQL: ежедневно, 1 копия. Бэкапы VPS: включены.

2. Срок логов, бэкапов, дата начала обработки

- Бэкапы MySQL: ежедневно с 00:15 МСК, хранится 1 копия
- Бэкапы VPS: автоматические, на диске сервера
- Логи PM2/nginx: срок ротации - уточнить на VPS
- Инфраструктура с 5.06.2026 (S3/VPS), MySQL с 24.08.2026
- Дата первых пользователей с ПДн - указывает ИП

3. Expo Push в web/PWA

Нет, не используется. Только для будущих native-сборок iOS/Android.

4. Запросы к YouTube/Google до действия пользователя

Что	Когда
Превью видео (обложки)	Да - вкладка Видео; proxy -> i.ytimg.com; без ФИО/email
Само видео	Нет - только по нажатию play
Переход на youtube.com	Только если пользователь сам нажал ссылку
Google Fonts	Нет - шрифты локально на сервере

5. Меры защиты - уже внедрено

- HTTPS (TLS), пароли scrypt, SMS-коды SHA-256 TTL 5 мин
- JWT-сессии, роли user/admin, проверка подписи Prodamus webhook
- Рекламные push - только после согласия + журнал push_consent_events
- Банковские карты не храним (Prodamus), политика конфиденциальности в app

Не внедрено (указать в заявлении честно)

- Автоудаление аккаунтов по таймеру (30 дней после отмены подписки - в политике, автоматизация частичная)
- Native push (EAS/APNs/FCM) - до настройки credentials

Полные ответы на 14 вопросов для уведомления РКН - раздел 27.

27. Уведомление Роскомнадзора - ответы (14 пунктов)

Только подтвержденные данные: код, nginx-конфиг, панель Timeweb 31.08.2026. Без предположений там, где указано "уточнить".

1. Адрес ЦОД MySQL и S3 (ФИАС)

MySQL Charming Aquila ID 4202401, IP 77.95.206.157. S3 daryadarcy-s3 ID 513637, регион ru-1. Зона ru-1 = SPB-3 (таблица Timeweb Cloud). Площадка SPB-3: Dataline, г. Санкт-Петербург, ул. Жукова, д. 43. Для формы: адрес в формате ФИАС - подобрать код на fias.nalog.ru по этому адресу (в коде приложения кода ФИАС нет).

2. Московский VPS и персональные данные

VPS daryadarcy-main, IP 200.165.234.36, Cloud MSK 50 (Москва). Основная БД ПДн - MySQL в Санкт-Петербурге, не на диске VPS. На VPS: журналы nginx/PM2, временная обработка запросов. Локальной копии БД пользователей нет. В уведомлении: БД - СПб; VPS - место обработки и хранения технических журналов, не основная база ПДн.

3. Адрес московского ЦОД (MSK-1, VPS API)

VPS daryadarcy-main: тариф Cloud MSK 50, зона доступности MSK-1 (Terraform ru-3), Москва. Cloud MSK 50 - название тарифа (2 CPU, 2 GB RAM, 50 GB NVMe), не отдельный ЦОД.

По официальной документации Timeweb Cloud (timeweb.cloud/docs/nashi-data-centry): облачные серверы в Москве размещаются в MSK-1, адреса площадок включают IXcellerate, ул. Подольских Курсантов, 15Б, ст1, Москва. Для уведомления РКН: указать этот адрес с пометкой "по данным Timeweb Cloud" ИЛИ получить письменное подтверждение от поддержки для VPS ID 8271015.

4. ПДн в журналах PM2/nginx

- Да: IP-адрес, URL запроса, User-Agent, метод, код ответа, время
- Нет намеренно: телефон, email, ФИО, пароли, SMS-коды, содержимое JWT
- PM2: возможны orderId/userId в отладочных строках webhook Prodamus - не полные ПДн

5. Срок хранения и ротация журналов PM2/nginx

Проверено на VPS daryadarcy-main (Ubuntu 24.04, hostname daryadarcy-main):

- nginx (/var/log/nginx/*.log): logrotate daily, rotate 14, compress, delaycompress - хранение ~14 суток
- PM2 (/root/.pm2/logs/daryadarcy-api-*.log): pm2-logrotate 3.0.0, max_size 10M, retain 14, compress true, rotateInterval 0 0 * * * (настроено 15.09.2026)

6. Резервные копии VPS

Из панели Timeweb: автобэкапы диска VPS включены, последняя копия 31.08.2026 13:00. Не подтверждено из панели: физический ЦОД хранения бэкапов, число копий, срок удаления. Ожидаемо: РФ, инфраструктура Timeweb - уточнить в поддержке или скрином раздела Бэкапы VPS.

7. MySQL backup - подтверждение

Timeweb MySQL (физические): включены, ежедневно с 00:15 МСК, хранится 1 копия (кластер 4202401, панель 31.08.2026).

Приложение (логические): server/_core/backup.ts - mysqldump --single-transaction, gzip; не чаще 1 раза в 24 ч (проверка каждые 6 ч); локально /var/www/daryadarcy/backups/; копия в S3 daryadarcy-s3/backups/mysql/. Последний успешный upload: 15.09.2026 07:07 UTC, ~479 KB.

8. Шифрование HTTPS/TLS - поля формы РКН

- Сертификат: Let's Encrypt (/etc/letsencrypt/live/daryadarcy.com/)
- Протоколы: TLS 1.2, TLS 1.3 (nginx deploy/nginx-daryadarcy.conf)
- Реализация: nginx 1.24.0 + OpenSSL 3.0.13 (Ubuntu 24.04, проверено 02.09.2026)
- Сертифицированные СКЗИ (ГОСТ, КриптоПро): в ИСПДн daryadarcy.com не используются

Как заполнить раздел "Шифровальные (криптографические) средства"

Раздел формы pd.rkn.gov.ru - отдельный блок "Использование шифровальных (криптографических) средств".

Для daryadarcy.com (HTTPS без ГОСТ-СКЗИ):

- Используются: да (TLS для HTTPS сайта и API)
- Наименование: OpenSSL 3.0.13 + nginx TLS 1.2/1.3 + сертификат Let's Encrypt (ISRG Root X1)
- Изготовитель OpenSSL: OpenSSL Project; сертификат: Let's Encrypt / ISRG
- Класс СКЗИ по приказу ФСБ: не применяется (не сертифицированные СКЗИ; TLS для транспорта)
- ЭЦП для подачи уведомления (КриптоПро на ПК ИП): указывать отдельно, если используется только для подписи формы, не в приложении

Скриншот выпадающих вариантов поля - см. docs/RKN-CRYPTO-FORM-GUIDE.md (сделать при заполнении формы на pd.rkn.gov.ru под учётной записью ИП).

9. YouTube - встроенный плеер или внешняя ссылка

- В приложении: HTML5 video, src=/api/yt/{id} - proxy через backend, не iframe YouTube
- Кнопка "Смотреть на YouTube" - внешняя ссылка только по нажатию пользователя
- Если videoUrl на S3 - воспроизведение с Timeweb S3 без YouTube

10. Загрузка ресурсов YouTube/Google до действия пользователя

Сценарий	До действия пользователя
Список видео (превью)	Да - /media/yt-thumb/ -> i.ytimg.com; ID ролика; cookie Google отбрасываются
iframe/скрипты/cookie Google на странице	Нет
Google Fonts CDN	Нет - шрифты локально
Страница ролика	Запрос /api/yt при открытии страницы ролика

При воспроизведении: IP и User-Agent браузера; email/телефон/userId DARYADARCY в YouTube не передаются.

11. Передает ли backend данные пользователя в YouTube/Google

При /api/yt/{id}: yt-dlp запрашивает youtube.com/watch?v={id}. Email, телефон, userId, имя не передаются. User-Agent и IP VPS (200.165.234.36). Превью: nginx -> i.ytimg.com, только ID ролика. Переход на youtube.com - из браузера пользователя, backend не участвует.

12. Push в web/PWA

Подтверждаем: Expo Push, APNs, FCM в web/PWA не используются. Push-tokens не собираются и не хранятся (registerNativePush только при Platform.OS != web). UI согласия на push в профиле на web скрыт.

13. Google Fonts, Analytics, Metrika, Firebase, Sentry

Подтверждаем - не используются в production web/PWA: Google Fonts CDN, Google Analytics, Яндекс.Метрика, Firebase Analytics, Sentry. Шрифты - локально в assets/fonts. @expo-google-fonts - npm-пакет с локальными файлами.

14. Меры защиты - фактически работают

Мера	Статус
HTTPS/TLS Let's Encrypt	работает
Пароли scrypt	работает
SMS SHA-256, TTL 5 мин	работает
JWT-сессии (jose)	работает

Подпись webhook Prodamus	работает
Роли user/moderator/admin + block	работает
admin_audit_log	работает
2FA TOTP admin	код готов, нужен ADMIN_TOTP_SECRET
Бэкап MySQL ежедневно	работает (Timeweb)
Бэкап MySQL app->S3	работает (cron 24ч)
Бэкап VPS	включен (Timeweb)
SMTP Yandex shop delivery	настроен на VPS

Частично: anonymize комментариев - stub.

Чеклист перед подачей (осталось у ИП / Timeweb)

- Код ФIAS для ул. Жукова, д. 43, СПб - fias.nalog.ru
- Письменное подтверждение Timeweb: адрес ЦОД для VPS 8271015 (MSK-1) - см. docs/TIMEWEB-RKN-REQUESTS.md
- Параметры бэкапов VPS: число копий, регион/ЦОД хранения - скрин + запрос Timeweb
- Скрин поля "криптографические средства" на pd.rkn.gov.ru - см. docs/RKN-CRYPTO-FORM-GUIDE.md
- Дата начала обработки ПДн пользователями - указывает ИП

29. Обновление для РКН (15.09.2026)

Сводка по запросу ИП для подготовки уведомления в Роскомнадзор и текущий статус продукта.

29.1. Ротация логов PM2

- Статус: выполнено 15.09.2026 на VPS daryadarcy-main (200.165.234.36)
- Модуль: pm2-logrotate 3.0.0 (pm2 install pm2-logrotate)
- Параметры: max_size 10M, retain 14 файлов, compress true, rotateInterval 0 0 * * *
- nginx: без изменений - logrotate daily, rotate 14, compress (~14 суток)

29.2. Согласие на обработку ПД при регистрации по email

- Статус: реализовано (app/login.tsx, mode=register)
- Отдельный чекбокс с текстом из shared/consent-texts.ts (EMAIL_REGISTER_CONSENT_LABEL)
- Без галочки кнопка "Создать аккаунт" неактивна; backend требует consentVersion
- Согласие логируется в БД (logUserConsent, consentKey email_register)
- SMS-вход: отдельный чекбокс (SmsCodeForm, SMS_LOGIN_CONSENT_LABEL)
- Для заявления: скрин экрана /login -> Регистрация с отмеченным чекбоксом

29.3. Поле СКЗИ в форме pd.rkn.gov.ru

Отдельной опции "класс СКЗИ не применяется" в форме обычно нет. Блок "Использование шифровальных (криптографических) средств": сначала "используются" / "не используются"; при "используются" - наименование, изготовитель, класс КСЗИ (КС1/КС2/КС3 или "иное").

Для daryadarcy.com: HTTPS через OpenSSL 3.0.13 + nginx TLS 1.2/1.3 + Let's Encrypt - не сертифицированные СКЗИ ФСБ. Рекомендация: "Используются" = да; класс - "Не применяется" в текстовом поле или "иное" + пояснение про TLS.

- Подробно: docs/RKN-CRYPTO-FORM-GUIDE.md
- Скрин выпадающего списка - сделать ИП при заполнении формы (pd.rkn.gov.ru)

29.4. Параметры резервного копирования (для формы)

Уровень	Что / как / где
Timeweb MySQL	Физические бэкапы, ежедневно 00:15 МСК, 1 копия; кластер 4202401, SPB-3
Timeweb VPS	Автобэкапы диска включены (параметры retention/ЦОД - скрин панели + запрос в поддержку)
Приложение	mysqldump -> .sql.gz -> /var/www/daryadarcy/backups/ + S3 backups/mysql/
Расписание app	Не чаще 1 раза в 24 ч; проверка каждые 6 ч при работе API
Локально на VPS	/var/www/daryadarcy/backups/*.sql.gz - хранение 14 суток, автоудаление
S3	backups/mysql/*.sql.gz - хранение 90 суток, автоудаление
Последний S3 backup	15.09.2026, daryadarcy-2026-09-15T07-07-16-869Z.sql.gz, ~479 KB
S3 бакет	daryadarcy-s3, endpoint s3.twcstorage.ru, регион ru-1 (SPB-3)

Timeweb: физический адрес ЦОД VPS MSK-1 и параметры автобэкапов диска VPS - запрос в поддержку + скрин панели (docs/TIMEWEB-RKN-REQUESTS.md). Локальные .sql.gz на VPS MSK-1 - копии ПДн на диске API-сервера; срок 14 суток.

29.5. Аккаунт после окончания Клуба

- Модель: после окончания подписки аккаунт сохраняется (бесплатный режим, без доступа к закрытым материалам)
- Автоудаление аккаунта при отмене подписки НЕ выполняется - только по явному запросу пользователя
- processScheduledAccountDeletions: удаление/обезличивание только если accountDeletionRequestedAt установлен; не ранее 30 дней после окончания оплаченного периода Клуба
- Тексты: privacy.tsx, legal personal-data, диалог удаления в profile - согласованы 15.09.2026

29.6. Продукт - критичное после запуска (не РКН)

29.5. Продукт - критичное после запуска (не РКН)

Приоритет	Задача	Срок	Статус
P2	Хранение ключей [illegible] на устройстве		

29.6. Недавние исправления (15.09.2026)

- Web deploy: курсив постов EB Garamond Italic; лицензия на музыку без ПД композитора
- Club music: Darcy's Autumn (лицензия в юр. документах, без скана с паспортными данными)
- Prodamus: исправлена привязка subscription ID при CLUB_PRICE=790 (требует deploy API)

30. Контакты

Владелец / оператор: ИП Левина Дарья Сергеевна

Email для пользователей и Prodamus: daryadarcyapp@yandex.ru

Сайт: https://daryadarcy.com

Технические вопросы аудита - к разработчику проекта.

Полный комплект markdown: docs/AUDIT-PACKAGE.md, ROSKOMNADZOR-DATA-MAP.md, PUSH-NOTIFICATIONS.md